

PROPOSAL TEKNIS KEAMANAN SISTEM PENERAPAN PROTOKOL AAA PADA SISTEM “BALIKIN”

PENDAHULUAN

1.1 Deskripsi Sistem

Sistem “Balikin” adalah proyek aplikasi berbasis web yang ditujukan untuk mengelola pelaporan dan pencarian barang hilang di lingkungan kampus. Sistem ini dibangun menggunakan arsitektur modern (React pada sisi *frontend* dan FastAPI pada sisi *backend*). Sistem ini melibatkan tiga aktor utama dengan peran yang berbeda: Admin, Petugas, dan Pencari.

1.2 Tujuan Proyek

Proyek ini difokuskan pada penerapan keamanan informasi dan kriptografi dasar yang terstruktur pada model AAA (*Authentication, Authorization, Accounting*). Pendekatan ini dipilih untuk memastikan perlindungan terhadap akses pengguna, pembatasan hak wewenang, serta pencatatan setiap tindakan krusial di dalam sistem.

IDENTIFIKASI ASET

Berdasarkan struktur kode dan kerangka kerja sistem, berikut adalah aset-aset informasi utama yang perlu dilindungi melalui skema AAA:

- Aset Autentikasi: Data kredensial pengguna (kata sandi) dan token sesi yang tersimpan di dalam basis data maupun di sisi klien.
- Aset Otorisasi: Data profil pribadi, daftar laporan barang hilang dan temuan, serta hak fungsi manajemen sistem yang tidak boleh diakses oleh pihak yang salah.
- Aset Akuntabilitas: Catatan log aktivitas (*activity logs*) sistem dan riwayat serah terima barang (*handover history*) antara petugas dan pencari.

RENCANA PENERAPAN AAA

1. Autentikasi (*Authentication*)

Fokus pada proses pembuktian identitas entitas yang mencoba mengakses sistem Balikin.

- *Hashing dan Salting Kata Sandi*: Menggunakan algoritma kriptografi satu arah (seperti bcrypt atau Argon2) ditambah dengan salt unik pada modul backend/auth.py untuk melindungi kata sandi agar tidak terbaca meskipun basis data berhasil dibobol.
- *Manajemen Sesi Berbasis Token*: Menggunakan *JSON Web Tokens* (JWT) yang ditandatangani secara kriptografis menggunakan algoritma HS256 atau RS256 untuk memvalidasi setiap permintaan dari klien tanpa perlu menyimpan sesi di server (*stateless authentication*).

2. Otorisasi (Authorization)

Fokus pada pemberian dan pembatasan hak akses terhadap sumber daya sistem setelah pengguna berhasil diautentikasi.

- *Role-Based Access Control* (RBAC): Membatasi eksekusi API pada FastApi berdasarkan peran yang terdaftar.
- *Admin*: Memiliki akses menyeluruh terhadap manajemen pengguna dan pemantauan aktivitas seluruh sistem.
- *Petugas*: Diberikan wewenang terbatas untuk fungsi operasional, yakni mendaftarkan barang temuan dan melakukan verifikasi atau penutupan laporan.
- *Pencari*: Hak akses sangat terbatas pada pembuatan laporan pribadi, penelusuran katalog publik barang temuan, dan pengelolaan profil pribadi.

3. Akuntabilitas (Accounting)

Fokus pada pencatatan, pemantauan, dan pembuktian setiap aktivitas untuk memastikan sifat nirangkal (*non-repudiation*) dan integritas data.

- *Tamper-Evident Logs*: Memodifikasi skema log aktivitas sistem sedemikian rupa sehingga setiap catatan (*record*) terkait secara kriptografis dengan catatan sebelumnya (*hash chain*). Hal ini bertujuan untuk mendeteksi apabila ada penghapusan atau modifikasi jejak audit oleh pihak tidak berwenang.
- *Tanda Tangan Digital (Digital Signature)*: Menggunakan kriptografi kunci asimetris pada modul serah terima barang. Petugas dan pemilik barang wajib membubuhkan persetujuan yang dikonversi menjadi tanda tangan digital sebagai bukti sah bahwa barang telah benar-benar dikembalikan kepada pihak yang tepat.